

Assessment 4

Secure and Monitor a Cloud Infrastructure

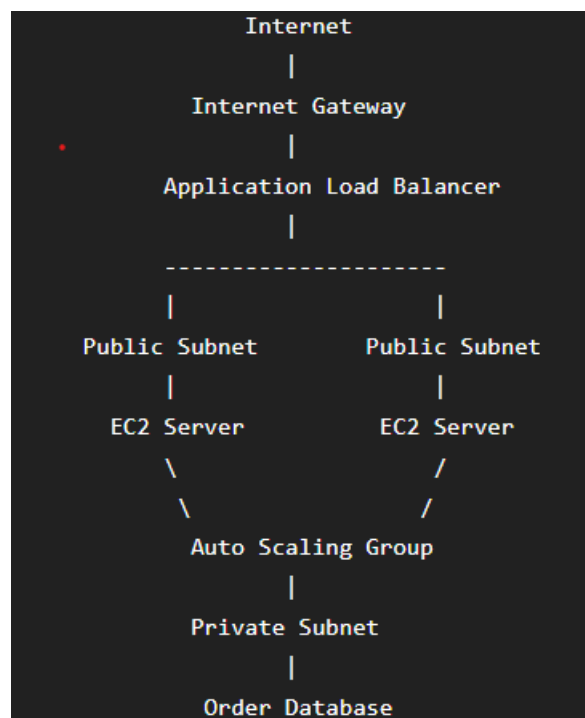
Section A — Concept Application

1. The founders want to move to the cloud to handle rapid growth. For each of the two on-prem components, identify which cloud service model (IaaS, PaaS, or SaaS) is the best replacement, and explain — using the shared responsibility model — which security tasks the team no longer has to handle once each component moves to the cloud.

ANS :

- Under the **shared responsibility model**, the cloud provider manages physical hardware, data centers, networking infrastructure, and other underlying infrastructure. With PaaS, the provider also manages the operating system and runtime platform.
 - The startup is still responsible for its application code, data, user permissions, IAM configuration, and security settings.
 - This reduces infrastructure maintenance and allows the company to focus on its food delivery application. The question specifically asks for IaaS, PaaS, or SaaS and the shared-responsibility impact.
2. Design a VPC-based networking architecture — subnet layout, load balancer type, auto-scaling trigger, and security group rules — that keeps the order-processing service responsive during the spike while keeping the order database's subnet fully isolated from direct internet access. Justify each component of your design.

ANS :



❖ **Security Groups**

ALB Security Group

- Allow HTTP port **80**.
- Allow HTTPS port **443**.
- Allow traffic from the internet.

❖ **Application Server Security Group**

- Allow application traffic only from the ALB security group.
- Allow SSH only from an administrator's trusted IP.

❖ **Database Security Group**

- Allow database traffic only from the application server security group.
- Do not allow direct internet access.

❖ **Justification**

- The ALB distributes incoming requests between multiple application servers. Auto Scaling can add servers when the evening traffic increases five times, keeping the application responsive.
- The database remains in a private subnet and cannot be accessed directly from the internet. This improves both **availability and security**. The assessment specifically requires subnet layout, load balancer, scaling trigger, and security-group rules.

3. Propose a storage strategy using S3 storage classes and lifecycle policies for each file type, and explain why EBS would be the wrong choice for either one.

ANS :

File Type	S3 Storage Strategy	Reason
Menu item photos	S3 Standard	Photos are frequently accessed by the mobile application, so they should remain in a frequently accessible storage class.
Delivery receipt PDFs	S3 Standard → Glacier	Receipts are rarely accessed and must be retained for 7 years, so they can be moved to a lower-cost archival storage class.

❖ **Why Not EBS?**

- Amazon EBS is **block storage designed primarily for EC2 instances**. It is not ideal for storing large collections of application objects such as photos and PDFs.
- S3 is more appropriate because it provides object storage, high durability, lifecycle policies, and different storage classes for optimizing cost.
- Therefore, I would use **S3 Standard for frequently accessed photos** and a **Glacier storage class for long-term receipt retention**.

4. Describe the least-privilege IAM approach you would take for this developer — the roles, policy scoping, and any AWS-managed vs. custom policy decisions — and explain specifically what would go wrong if you instead attached the AWS-managed AdministratorAccess policy “just to save time.”

ANS :

- ❖ The developer should have:
 - Read-only access to production logs.
 - Read-only access to the required S3 files.
 - No permission to modify IAM policies.
 - No permission to delete AWS resources.
- ✓ The permissions should be restricted to the specific log groups and S3 bucket required by the developer.
- ✓ I would use **AWS-managed read-only policies** where they closely match the requirement. If they provide excessive permissions, I would create a **custom IAM policy** with only the required actions and resources.
- ❖ **Why AdministratorAccess is Dangerous**
- ✓ Attaching AdministratorAccess just to save time is a bad practice because it gives the developer broad access to AWS resources.
 - ❖ The developer could accidentally or intentionally:
 - Delete resources.
 - Modify IAM users or policies.
 - Change security configurations.
 - Access sensitive data.
 - Disable security controls.
- ✓ Therefore, the **principle of least privilege** should always be followed. The assessment specifically asks for roles, policy scoping, AWS-managed vs custom policies, and the risk of AdministratorAccess.

5. The Lambda's environment variables (which hold the sensitive secret) must be encrypted with a customer-managed KMS key that rotates automatically every year. Explain how KMS key rotation applies here, and justify why a customer-managed key is the better choice over the AWS-managed key for this specific use case.

ANS :

- ✓ The Lambda function contains a sensitive secret in its environment variables. I would use a **customer-managed AWS KMS key** to encrypt the environment variables.
- ✓ The key would have **automatic annual rotation enabled**.

❖ How Rotation Works

- ✓ When automatic rotation is enabled, AWS KMS periodically generates new cryptographic key material for the customer-managed key. The key itself keeps the same key ID, while AWS maintains previous key material so that previously encrypted data can still be decrypted.
- ✓ The Lambda function can continue using the KMS key without manually changing the key identifier.

❖ Why Customer-Managed KMS Key?

- ✓ A customer-managed key is preferred for this scenario because it provides greater control over:
 - Key permissions.
 - IAM access.
 - Key policies.
 - Key rotation.
 - Key disabling.
 - Auditing through CloudTrail.
 - Key lifecycle management.
 - ✓ An AWS-managed key provides less direct control over key management.
6. Design a monitoring and auditing approach — naming the specific AWS services you would use for logging, auditing, and alerting — that would have caught both issues immediately. Explain how this fits into an overall “secure and monitored” cloud infrastructure for the platform.

ANS :

1) IAM Monitoring

- ✓ Use **IAM Access Analyzer** to identify overly broad IAM policies and unintended access.

2) **API Auditing**

- ✓ Enable **AWS CloudTrail** to record IAM policy changes, S3 configuration changes, and other important API activities.

3) **S3 Monitoring**

- ✓ Use **AWS Config** rules to detect when an S3 bucket becomes publicly accessible.

4) **Alerting**

- ✓ Use **CloudWatch** to monitor important security events and create alarms.

AWS Service	Purpose
AWS CloudTrail	Records AWS API calls and user activities.
AWS Config	Monitors resource configuration changes and compliance.
IAM Access Analyzer	Identifies unintended external access and overly broad permissions.
Amazon CloudWatch	Monitors events and creates alarms.
Amazon SNS	Sends notifications when important security events occur.

Section B — Practical Coding Tasks

1. VPC Setup for the Order-Processing Service

ANS :

❖ Create a Bash script that:

- Creates a VPC.
- Creates two subnets.
- Creates and attaches an Internet Gateway.
- Creates a route table.
- Associates the public subnet with the route table.
- Applies appropriate tags.

✓ Type a code regarding an requirements

2. Tiered Storage for Menu Photos and Receipts

ANS :

❖ Create an S3 bucket and configure lifecycle rules so that:

- Objects are stored normally.
- Objects older than 30 days transition to Glacier.
- Objects older than 365 days are deleted.

✓ Type a code regarding an requirements

Object Uploaded



S3 Storage



After 30 Days



S3 Glacier



After 365 Days



Object Deleted

3. Least-Privilege Role for the Delivery-Tracking Service

ANS :

✓ After the code run the output you may looks like

- The role can:
 - List the specified S3 bucket
 - +
 - Read objects from the bucket
- It **cannot**:
 - Delete objects
 - Upload objects
 - Modify IAM
 - Access other S3 buckets

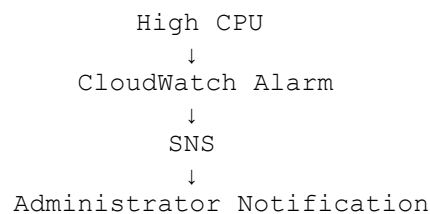
4. Secure and Monitored Order Database Backup

ANS :

✓ After the code run the output you may looks like

- CloudWatch alarms can send notifications through **Amazon SNS** when a threshold is exceeded.

❖ For example:



✓ This helps administrators detect database performance problems and respond before they cause a major service outage.

Section C — Mini Capstone Project

1. Build a console-based (menu-driven) Bash script that provisions and secures the core AWS infrastructure for the food delivery platform's backend, combining VPC networking, least-privilege IAM, encrypted storage, and CloudWatch monitoring into a single working program — the same scope as Module 8's Secure & Monitor a Cloud Infrastructure project.

ANS :

- ✓ Run the script regarding on requirements

```
=====
FOOD DELIVERY CLOUD MANAGEMENT
=====
```

1. Provision Infrastructure
2. Apply Security & Encryption
3. Enable Monitoring & Alerts
4. View Resource Summary
5. Exit

Option Function

- | | |
|----------|---|
| 1 | Creates VPC, public/private subnets, Internet Gateway and route table |
| 2 | Creates KMS key, enables rotation, creates encrypted S3 bucket and least-privilege IAM role |
| 3 | Creates monitoring/alerting resources |
| 4 | Displays created AWS resource IDs |
| 5 | Exits the program |

Section D — AI-Augmented Learning

ANS

- ✓ I used an AI tool to generate a Bash script using AWS CLI for creating basic cloud infrastructure.

- ❖ The generated script included resources such as:

- VPC
- Public and private subnets
- Internet Gateway
- S3 bucket
- IAM role
- KMS encryption
- CloudWatch monitoring

- ❖ Security Problems Identified

Issue	Risk	Improvement
IAM permissions were too broad	Users/services may access unnecessary AWS resources	Use least-privilege permissions
S3 bucket could potentially be publicly accessible	Sensitive files could be exposed	Enable S3 Block Public Access
Wildcard resources such as *	Policy may affect all resources	Specify exact resource ARNs
Encryption was not guaranteed	Data could be stored without encryption	Enable default S3 server-side encryption
No monitoring/alerting	Security changes may go unnoticed	Use CloudTrail, CloudWatch and SNS

- ❖ Security Improvements

1. **Least-Privilege IAM**

- The IAM role is allowed only s3:GetObject and s3:PutObject for the specific application bucket instead of giving broad AWS permissions.

2. **S3 Public Access Block**

- All public access to the S3 bucket is blocked to prevent accidental exposure of application data.

3. **KMS Encryption**

- A customer-managed KMS key is created and used for S3 server-side encryption.

4. **Automatic Key Rotation**

- Automatic KMS key rotation is enabled to improve long-term key security.

5. **Private Subnet**

- Backend resources can be placed in the private subnet so they do not require direct internet access.
- ✓ These improvements follow the same security principles required by the assessment: **least privilege, encrypted storage, protected networking, and monitoring.**

❖ **Final Security Review**

- ✓ The AI-generated script was useful for creating the initial infrastructure quickly, but it required manual security review before deployment. The main improvements were restricting IAM permissions, blocking public S3 access, enabling KMS encryption, enabling automatic key rotation, and separating public and private resources.